

-

File No.: EXP202204668

RESOLUTION OF FILE OF ACTIONS

From the actions carried out by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: On April 21, 2022, the Director of the Spanish Agency for Data Protection agreed to initiate investigative actions regarding the facts described below:

As a result of the communication dated March 30, 2022, made by the SECRETARY OF STATE FOR DIGITALIZATION AND ARTIFICIAL INTELLIGENCE (hereinafter SEDIA), in which this Agency was informed of two writings from the ASSOCIACIÓ PER A LA DEFENSIÓ DE L'ADMINISTRAT I EL CONTRIBUENT (ADAC) and ANF AUTHORITY OF CERTIFICATION (ANF AC), which report alleged irregularities related to the issuance of qualified electronic certificates by trust service providers. The practices carried out by various entities are referenced, consisting of the instrumentalization of qualified electronic certificates for unauthorized access to Public Administration sites and the obtaining of reports from them, such as criminal records, tax declarations, Social Security information, and information from the Central Risk Information of the Bank of Spain (CIRBE).

The opening of investigative actions is urged due to the need to analyze the implications regarding personal data protection and information security, in order to clarify the reported facts.

Claimed: CIRBOX TECNOLOGÍA Y SEGURIDAD, S.L. with NIF B88571310.

Facts according to statements from the claiming party:

SEDIA forwards the complaints filed by ANF AC and ADAC that were directed to that agency. In them, a possible fraudulent use of electronic certificates is stated to access and sell the personal information of third parties (the holders of the certificates) through the use of the CIRBOX platform (whose responsible party is CIRBOX TECNOLOGÍA Y SEGURIDAD, S.L., hereinafter CIRBOX).

They indicate that with the instrumentalization of qualified electronic certificates, they are de facto selling to third parties private and confidential information of citizens and companies. It is indicated that the certificates may have been issued without the knowledge of the holders, allowing access to information related to their holders from different Public Administrations.

They provide a link to a video about the operation of the CIRBOX platform, in which it is observed that the client of the platform (usually a company) must enter the mobile phone number and the email address of the person from whom the data is to be obtained (data holder, hereinafter end user).

The claimants point out that the client of the platform could register their own phone number instead of the end user's phone number, and likewise with the email address, thus accessing the data without the knowledge of its holder, the end user.

They state that they have conducted tests by registering as a client of the platform, and in three completed requests (related to two different people), the same email address was entered as the data of the end users, which CIRBOX should have identified as that of its client, and the same mobile phone number for all of them.

A second income report was requested regarding one of those persons, whose request was canceled by CIRBOX, which claimed as a reason that the email and mobile phone had been repeated from previous requests.

A request was made in the name of a new end user, providing the ID of another person, which was detected by CIRBOX, canceling the request, communicating the cessation of the relationship, and canceling access to the platform.

They indicate that there is no or is not disclosed the privacy policy of the service, that no contract of data processing manager is signed, that the end user is not informed of the processing of their personal data, that they do not have the explicit consent of the user, and that the reports can be downloaded as many times as desired.

Date on which the reported facts took place: March 7, 2022.

SECOND: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the investigative powers granted to

control authorities in Article 57.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following aspects:

INVESTIGATED ENTITIES

During the present actions, the following entities have been investigated:

CIRBOX TECNOLOGÍA Y SEGURIDAD, S.L. with NIF B88571310.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/17

RESULT OF THE INVESTIGATION PROCEEDINGS

POINT 1. A physical inspection has been carried out at CIRBOX TECNOLOGÍA Y SEGURIDAD, S.L. (CIRBOX), the entity responsible for the CIRBOX platform. During the inspection, its representatives stated the following:

“CIRBOX is a limited liability company with an annual sales volume of approximately 25,000 euros and 5 employees, which was established in 2020, although it actually began its activity in 2022.

It offers a SaaS (Software as a Service) through the CIRBOX platform, available via web access and API for the clients who contract it. This platform allows CIRBOX clients to obtain reports issued by various Public Administrations to their holders, both natural and legal persons, at their request. The reports for natural persons are as follows: Social Security work life report, Report from the Central Risk Information Service of the Bank of Spain (CIRBE), Income report and model 347 from the AEAT.

The service is primarily designed for large companies that provide financing to their clients [end users] in the marketing of their products, and that, for the study of this financing, request documentation from their clients such as the aforementioned reports. Through the CIRBOX platform, the reports are obtained directly from the Public Administrations using a digital certificate from the data holder, ensuring their authenticity. However, CIRBOX clients are required to inform their clients (hereinafter end users) that they can manage the request for their reports directly from the Public Administrations by their own means, to proceed with their delivery in paper or other formats, or optionally authorize the CIRBOX service for obtaining reports via digital certificate. CIRBOX agrees with each client individually on the information that should be included in their sales arguments used by their managers.”

“The digital certificates of the end users, used for obtaining reports through the CIRBOX platform, are issued specifically for this purpose, so they can be considered one-time use certificates, with this use being solely and exclusively for the request for the issuance of the required reports from the Public Administrations. It should be noted that, for technical reasons, to obtain some reports such as those from the CIRBE, it is necessary to use the certificate twice, due to the very operation of that organization. Additionally, on holidays and weekends, the CIRBE does not provide service, so, combined with possible availability failures, obtaining a report may take several days, which is why digital certificates are issued with a validity period of one week. Once the certificate expires, one week after its issuance, it cannot be used. There are two types of access profiles to the platform for CIRBOX clients:

- Operator profile, which only allows managing report requests, to register them and consult pending ones, but without viewing the reports once obtained.
- Supervisor profile, which can both request and view the reports.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/17

As a standard practice, and according to their needs, a single access as a supervisor to the CIRBOX platform is created for clients, along with several accesses as operators, to limit the visibility of reports by client employees who do not need it for the performance of their functions.

The REGULATION (EU) No 910/2014 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of July 23, 2014, on electronic identification and trust services for electronic transactions in the internal market, and repealing Directive 1999/93/EC (hereinafter eIDAS Regulation) requires them to comply with three essential requirements for the issuance of a digital certificate:

- That the user proves their capacity for representation: for a natural person through their identity document (DNI or NIE), for a legal entity through a power of representation.
- A proof of life that certifies the identity of the applicant.
- The accreditation of the unequivocal will of the applicant that they want the certificate.

Therefore, CIRBOX has implemented the following measures in its process:

- It collects a copy of the identity document (DNI or NIE) of the end user, which is provided by the CIRBOX client.
- CIRBOX delegates to its client (acting as the In-Person Verification Point or PVP) the accreditation of the identity of the end user, sending CIRBOX a certificate of identification of the applicant. For this purpose, CIRBOX, as a Registration Authority (RA), signs a PVP agreement with its client, who commits to verifying the identity of the end user according to the criteria established in the eIDAS Regulation.
- CIRBOX collects the acceptance of the end user using the contact details provided by their client (email address and mobile phone number), secured through a two-step process that includes sending an SMS (short message) to the user's mobile with a OTP (One Time Password) that the user must enter for the issuance of the digital certificate. The user is informed of both the terms and conditions of the service and the privacy policy (the latter in two layers).

"Furthermore, both a legal representative of the CIRBOX client and the employees of the client authorized to perform PVP tasks sign a document annexed to the PVP agreement titled 'Registration of Internal Personnel for PVP Tasks' in which the individuals who will perform these tasks accept the following instructions regarding the compliance with the in-person verification functions for the issuance of digital certificates:

- Identify the applicants for digital certificates.
- Verify the accuracy and authenticity of the information provided by the applicant (end user).
- Carry out the comparison of the copies of the documentation against the original presented to process the formalization of the service provision contracts for certification with the applicant.
- Deliver the documentation presented by the applicant to CIRBOX so that it can authenticate and archive it.
- If applicable, inform the applicants of the importance and responsibility that digital certificates entail.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/17

- To know and respect the provisions set forth in the procedure for in-person verification and the certification and CPS policies published on the website of the Certification Authority (CA)

www.uanataca.es.

"There are no further instructions on how to collect the mobile phone number and email address of the user, data that will be used to obtain the final user's authorization in two steps, as each client follows their own procedure within their lines of business to obtain the consent of the final users (their clients) for the processing of this data and the rest of their personal data. As indicated, CIRBOX acts as the Registration Authority (RA) and the client of CIRBOX acts as the PVP responsible for collecting the data, verifying its accuracy, and checking the identity of the final user for the purpose of issuing the digital certificate necessary for obtaining the reports. Due to the very nature of the certificate issuance service, the entities involved are subject to control.

On the other hand, a system has been implemented to detect that the mobile phone or email address of the final users is not repeated in different requests. A maximum limit of two pending requests for the same ID number (DNI) has also been established. Additionally, an operator from CIRBOX performs a series of manual checks on the request before the issuance of the digital certificate:

- Verification that the name and surname data and DNI number of the request match those of the image of the provided DNI document, as well as those of the identification certificate and the certificate itself.

- Verification that the DNI is valid.

Furthermore, for the effective provision of the service, it is required that the final user accepts it through the aforementioned two-step procedure, as well as that they accept that the reports will be delivered to the client of CIRBOX. The certificates are issued by the entity UANATACA, SA as the Certification Authority (CA), and the user is also informed of this.

The CA accepts and issues the certificates whose requests are indicated by the RA as being correct. The CA audits the RAs in advance, verifying that their processes for identifying the users holding the certificates are correct."

"During the process, the final user must choose the PIN for the issuance of the certificate. This PIN is encrypted in the computer systems and is not accessible by any employee of CIRBOX, being automatically used by the system when requesting reports from public bodies.

The reports are delivered exclusively to the client of CIRBOX who requested them, and they cannot be accessed from CIRBOX or any other client. No employee of CIRBOX has computer access to the contents of the reports. Therefore, they can only view the data and statuses related to the requests for the reports to perform the functions assigned to them, but not the reports themselves. The reports are available for download for 30 days, and after this time, they are deleted.

To date, CIRBOX does not perform identity checks of final users by remote means such as videoconferencing or video identification, a path that..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/17

Refers to Article 7.2 of Law 6/2020, of November 11, regulating certain aspects of electronic trust services, and Order ETD/465/2021, of May 6, which regulates remote identification methods by video for the issuance of qualified electronic certificates."

Attached to the inspection report is the contract model that CIRBOX signs with its clients for the provision of the service, which in ANNEX II of Personal Data Protection cites CIRBOX as the data processor and its clients as the data controllers. It is verified that it states that it is signed in compliance with the provisions of Articles 28 and 29 of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (hereinafter GDPR).

Attached to the inspection report are the model of the PVP agreement and the model of identification certificate or proof of life. It is verified that the PVP agreement states that the issuance of a digital certificate requires a verification of the identity of the applicant (Proof of Life) according to the eIDAS Regulation and that the identification will be carried out by internal personnel and according to the criteria established in the aforementioned Regulation.

Attached to the inspection report is a copy of the model document "Registration of internal personnel for PVP tasks." It is verified that in the document, the personnel dedicated to PVP tasks are informed of the instructions, specifically, to verify the accuracy and authenticity of the information they provide, to compare the copies of the documentation with the original presented, as well as to deliver the documentation to CIRBOX so that it can authenticate and archive it.

It is also stated as instructions that they must know and respect what is established in the PVP procedure and the certification policies published on the website of the certification authority UANATACA, as well as, where applicable, inform applicants of the importance and responsibility that digital certificates entail.

Attached to the inspection report is a copy of the Certification Practices Statement of UANATACA and the ISO/IEC 27001 certificate.

The content of the audit document that UANATACA, as the CA, has carried out is confidential; during

the inspection, a summary of conclusions is extracted in which the qualifications of "Compliant" are read in the chapters of knowledge and procedures, as well as that "the procedure complies with what is established in the Certification Practices Statement of UANATACA."

They provide certification that CIRBOX has implemented and maintains an Information Security Management System for the Information Systems that support the business processes related to the issuance of digital certificates and electronic notifications, storing digital certificates in the cloud and obtaining reports from public administrations, in accordance with the state of applicability in force at the date of issuance of the certificate (First issuance: 10/12/2019 and last 16/03/2021) complying with the requirements of the ISO/IEC 27001:2013 standard.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/17

(...).

They are aware of a complaint filed with the SEDIA, which has made a request to them. They assume that the claim submitted to the Spanish Agency for Data Protection may come from the same claimants.

Attached to the inspection report are copies of the complaint filed and a copy of the order of initiation issued by the judge.

POINT 2. During the inspection carried out, the following checks were made regarding the procedure for issuing certificates and obtaining reports from public bodies using the CIRBOX platform:

- It has been verified that during the report request process, the CIRBOX client must attach an image of the ID card and the authentication certificate of the end user for the submission button to be enabled.

- It has been verified that a CIRBOX operator must check this documentation against the request data to validate it. The operator's checks may result in the cancellation of the request for the following reasons, recorded in the application: expired ID, ID does not correspond to the request, ID not legible or not an ID, identification with incorrect data, identification with signature problem, incorrect identification document, identification does not identify the applicant, mobile or email already used by another.

- It has been verified that the email and mobile phone data entered during the report request process are used to request authorization from the end user, informing during the process of different aspects:
 - . In the end user's email account provided during the report request, an email is received with the text "to continue with your report request, please click on the following link."

- . In this email, the links "Legal Notices" appear, and within the text of the legal notice, a link to the "Privacy Policies."

- . Accessing the link provided in the email to continue with the report request, it is verified that access is granted to the so-called landing page for the end user, where it is explained that the CIRBOX service facilitates the obtaining of reports (the type of report they have requested is specified), which will be obtained on their behalf and that a digital certificate will be issued for that exclusive use, through CIRBOX, informing of the destination of the report (CIRBOX client who requested it).

On this landing page, the user is informed that they must request, by clicking the "send code" button, the sending of a code that will arrive at their mobile line (the mobile number is specified) and that they must enter the received code in the field, as well as choose a PIN. It is verified that there is indeed a button to request the code and text entry fields for the received code and for choosing the PIN. Basic information about data protection is also provided. In the text of Basic Information on Data Protection, it is indicated that the purpose is to provide the user with the services offered through the CIRBOX platform, that data is communicated for the issuance of the electronic certificate to UANATACA, as Certification Authority (CA), and to the CIRBOX client who has requested the report,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

and that they have the right to access, rectify, or delete the data, as well as other rights recognized in the Data Protection regulations. It is indicated that for additional and detailed information, the privacy policy can be consulted.

It is verified that there are two links on the landing page to "Service Conditions" and "Detailed Privacy Policy," which are downloaded during the inspection.

It has been confirmed that by pressing the "send code" button, a code is received on the mobile phone specified as that of the end user. It is verified that upon entering said code and choosing a PIN for the certificate, at the end of the landing screen process, a notification is received at the email address specified in the field called "Email for report delivery," from the client of CIRBOX, indicating that the requested report can be accessed.

- By accessing the CIRBOX platform using the user credentials that were used to create the report request, it is confirmed that the request is in "completed" status. The existence of a download button for the requested report is verified.

- Checks were made regarding the views and accesses to the CIRBOX platform available to CIRBOX employees, and it is verified that the data that can be viewed includes the date, the request reference, the full name of the end user, the CIF or NIF, the type of report requested, and the status of the request (among the statuses are initiated, pending client, canceled, completed). No access to the content of the reports is found.

- The existence of canceled requests is verified.

POINT 3. During the inspection proceedings, the following regulatory references have been identified as relevant:

- REGULATION (EU) No 910/2014 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of July 23, 2014, on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC.

- Law 6/2020, of November 11, regulating certain aspects of trust electronic services.

In its articles 18 and 20, regarding infringements and Authority:

"2. Very serious infringements are:

- b) The issuance of qualified certificates without carrying out all prior checks related to the identity or other circumstances of the certificate holder or the power of representation of the person requesting it on their behalf, as indicated in Regulation (EU) 910/2014 and in this Law, when it affects the majority of the qualified certificates issued in the year prior to the initiation of the sanctioning procedure or since the start of the provider's activity if this period is shorter.

3. Serious infringements are:

- b) Acting in the market as a qualified trust service provider, offering trust services as qualified or using the trust label "EU" without having obtained the qualification of the aforementioned services.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

- d) Failing to adequately protect the data for the creation of signatures, seals, or website authentication whose management has been entrusted to them in the manner established in Article 9.1.b) of this Law.

- h) The issuance of qualified certificates without carrying out all prior checks regarding the identity or other circumstances of the certificate holder or the power of representation of the person requesting it on their behalf, as indicated in Regulation (EU) 910/2014 and in this Law, when it does not constitute a very serious infringement.

[...]

Article 20. Sanctioning Authority.

The imposition of sanctions for non-compliance with the provisions of this Law shall correspond, in the case of very serious infringements, to the head of the Ministry of Economic Affairs and Digital Transformation, and in the case of serious and minor infringements, to the head of the State

Secretariat for Digitalization and Artificial Intelligence.”

- Order ETD/465/2021, of May 6, regulating remote identification methods by video for the issuance of qualified electronic certificates.

CONCLUSIONS

The inspection carried out has revealed that the CIRBOX platform is primarily designed for companies that offer financing to their clients in the marketing of their products, and that for the study of this financing, they request reports that certify their situation. The aforementioned platform facilitates the obtaining of reports, which are delivered directly to the company that requests them.

It has been evidenced that the CIRBOX platform uses digital certificates for access to the electronic offices of public administrations and that in relation to these digital certificates, the entity CIRBOX, responsible for the platform, acts as a Registration Authority (RA) and UANATACA as a Certification Authority (CA).

The client companies of CIRBOX act as a Physical Verification Point (PVP) in order to certify the identity of the end user when applying for the electronic certificate.

Regarding the accreditation of the identity of the data holder, it is evident that the following controls exist:

- CIRBOX signs a PVP agreement with its client company.
- In these PVP agreements, it is stipulated that identification will be carried out by internal personnel of the client company and according to the criteria established in the eIDAS Regulation.
- At the time of identification, a certificate must be issued, which is sent to CIRBOX to certify the identification, along with an image of the identity document.
- The specific employees of the client who will perform the identification tasks of the holders of the digital certificates sign a document where they are authorized to do so and informed of the instructions for identification, including among other instructions the verification of the accuracy and authenticity of the information.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/17

provided, and the comparison of the copies of the documentation with respect to the original presented.

Client companies sign a service provision contract with CIRBOX with an annex on Data Protection.

It has been evidenced that within the process of requesting digital certificates and reports, the phone number and email address of the end user are used, informing them through these channels of both the terms and conditions of the service and the privacy policy, the latter in two layers. It is also informed about the issuance of the certificate, indicating that it will be used solely for the purpose of obtaining the reports and providing them to the company that requests them, and from the certification authority (CA) that issues it. Acceptance for the issuance of the certificate and the reports is obtained through a process with an OTP key directed to the end user's mobile phone.

It is noteworthy that for data appropriation through identity theft to occur, the entity acting as the PVP would need to breach its commitments and also introduce its own mobile number, instead of the number of the data subject, to receive the OTP key and complete the acceptance process, as well as its own email address to receive the information. CIRBOX has implemented a control “Mobile or Email already used by another” to prevent these data from being repeated in different requests, and the claimants themselves cite these controls as obstacles they have encountered when attempting to simulate a possible fraud.

Other controls of CIRBOX may result in the cancellation of the request for the following reasons, recorded in the application: Expired ID, ID does not correspond to the request, ID not legible or not an ID, identification with incorrect data, identification with signature problem, incorrect identification document, identification does not identify the applicant. It has been verified that there are canceled requests.

Regarding the data retention period, the collected privacy policy specifies one week for the digital

certificate and one month for the reports. Representatives of the entity have stated that the certificate is issued exclusively for the issuance of the requested reports and that the reports are available for download for a period of one month exclusively for the company that requested them.

CIRBOX has declared that its employees do not have access to the reports, only to the status of the requests, and checks conducted in the entity's systems have found no evidence of access to the reports by CIRBOX employees.

There is certification that CIRBOX has implemented and maintains an Information Security Management System for the information systems that support the business processes for managing the issuance of digital certificates, according to standard ISO/IEC 27001:2013. There is also a Certification Practices Statement from UANATACA, Certification Authority.

It has been revealed that CIRBOX has filed a complaint against ANF AC for document forgery, stating that they have made a

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/17

contracting with the aim of provoking behaviors that could be confused with regulatory breaches of CIRBOX solely for the purpose of filing complaints, and indicating that ANF AC is an entity that operates as a competitor of CIRBOX in the same economic sector.

There is specific regulation regarding qualified electronic certificates and the identification of the holders for their issuance.

LEGAL GROUNDS

I

Competence

In accordance with the functions conferred to each supervisory authority by Article 57.1 a), f), and h) of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR) and as provided in Articles 47 and 48.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to resolve these investigative actions.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Legality and security of processing

Article 6 of the GDPR, under the heading "Lawfulness of processing," details in its paragraph 1 the circumstances under which data processing is considered lawful:

"1. Processing shall be lawful only if at least one of the following applies:

- a) the data subject has given consent to the processing of his or her personal data for one or more specific purposes;
- b) processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract;
- c) processing is necessary for compliance with a legal obligation to which the controller is subject;
- d) processing is necessary in order to protect the vital interests of the data subject or of another natural person;
- e) processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller;
- f) processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular when the data subject is a child.

The provision in point f) of the first paragraph shall not apply to processing carried out by public authorities in the performance of their tasks.”

In turn, Article 6.1 of the LOPDGDD indicates, regarding the processing of personal data based on the consent of the affected party that: “1. In accordance with the provisions of Article 4.11 of Regulation (EU) 2016/679, consent of the affected party means any freely given, specific, informed, and unambiguous indication of the data subject's wishes by which he or she, by a statement or by a clear affirmative action, signifies agreement to the processing of personal data concerning him or her (...).”

For its part, the security of processing, as laid down in Article 32 of the GDPR, establishes that:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of processing, as well as the varying risks of likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which shall include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident;
- d) a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, account shall be taken, in particular, of the risks that are presented by processing, in particular as a result of the accidental or unlawful destruction, loss, alteration of, or unauthorized disclosure of, or access to personal data transmitted, stored, or otherwise processed.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may be used as an element to demonstrate compliance with the requirements set out in paragraph 1 of this Article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and who has access to personal data does not process such data except on instructions from the controller, unless he or she is required to do so by Union or Member State law.”

Recital 74 of the GDPR states:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/17

"It must be established that the data controller is responsible for any processing of personal data carried out by themselves or on their behalf. In particular, the controller must be obliged to implement appropriate and effective measures and must be able to demonstrate compliance of the processing activities with this Regulation, including the effectiveness of the measures. Such measures must take into account the nature, scope, context, and purposes of the processing, as well as the risk to the rights and freedoms of natural persons."

It should be noted that the GDPR in the aforementioned provision does not establish a list of security measures applicable according to the data being processed, but rather states that the controller and the processor shall implement technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of likelihood and severity to the rights and freedoms of the data subjects.

Furthermore, the security measures must be adequate and proportionate to the detected risk, indicating that the determination of the technical and organizational measures must be made taking into account: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident,

verification processes (not audits), evaluation, and assessment of the effectiveness of the measures. In any case, when assessing the adequacy of the level of security, particular attention shall be paid to the risks posed by the processing of data, as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial damage.

In this same regard, Recital 83 of the GDPR states that:

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or processor must assess the inherent risks of the processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation with respect to the risks and the nature of the personal data to be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, particularly those that could cause physical, material, or immaterial damage.” The integrity and confidentiality of personal data is guaranteed in section 1.f) of Article 5 of the GDPR. In turn, the security of personal data is regulated in Articles 32, 33, and 34 of the GDPR, which govern the security of the data.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
14/17

treatment, the notification of a personal data security breach to the supervisory authority, as well as the communication to the data subject, respectively.

Firstly, regarding Article 6.1 of the GDPR, the documentation in the file does not reveal that the conduct of the entity CIRBOX may be contrary to the principle of lawfulness.

The entity CIRBOX uses digital certificates for access to the electronic headquarters of public administrations and in relation to these digital certificates, the entity CIRBOX, responsible for the platform, acts as a Registration Authority (RA).

Indeed, a Registration Authority (RA) is an entity that unequivocally identifies the applicant for a certificate. The Registration Authority provides the Certification Authority with the verified data of the applicant so that the Certification Authority can issue the corresponding certificate, and UANATACA acts as the Certification Authority (CA).

It should be noted that a Certification Authority (CA) is a trusted entity responsible for issuing and revoking digital certificates used in transactions and electronic signatures. This trust is achieved thanks to the figure of the CA, which acts as an intervening party in the relationship between companies or between companies and individuals. Thus, when any transaction occurs between two parties, the CA provides trust to the documents managed and signed as it is not an interested party.

Thanks to the infrastructure of cryptographic keys that a Certification Authority has, the identity of the signer as well as the content of the transactions carried out are trusted and guaranteed.

Some of the functions of the Certification Authority include: providing services such as the publication of certificates, lists of revoked certificates, validity checks of certificates, etc. Additionally, the CA records the exact date and time when a document has been electronically signed, which is known as timestamping.

Likewise, the client companies of CIRBOX act as a Physical Verification Point (PVP) in order to verify the identity of the end user when applying for the electronic certificate.

Regarding the accreditation of the identity of the data subject, it is evident that the following controls exist:

- CIRBOX signs a PVP agreement with its client company.
- In these PVP agreements, it is stipulated that identification will be carried out by internal personnel of the client company and according to the criteria established in the eIDAS Regulation.
- During the identification act, a certificate must be issued, which is sent to CIRBOX to verify the

identification, along with an image of the identity document.

- The specific employees of the client who will carry out the identification tasks of the holders of the digital certificates sign a document where they are authorized to do so and informed of the instructions for identification, including among other instructions the verification of the accuracy and authenticity of the information.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
15/17

provided, and the comparison of the copies of the documentation with respect to the original presented.

Client companies sign a service provision contract with CIRBOX with an annex on Data Protection. In the case at hand, within the process of requesting digital certificates and reports, the phone number and email address of the end user are used, informing them through these channels of both the terms and conditions of the service and the privacy policy, the latter in two layers. It is also informed about the issuance of the certificate, indicating that it will be used solely for the purpose of obtaining the reports and providing them to the company that requests them, and of the certification authority (CA) that issues it. Acceptance for the issuance of the certificate and the reports is obtained through a process with an OTP key directed to the end user's mobile.

Therefore, for data appropriation through identity theft to occur, the entity acting as PVP would need to breach its commitments and also introduce its own mobile number, instead of the number of the data subject, to receive the OTP key and complete the acceptance process, and its own email address to receive the information. CIRBOX has implemented a control "Mobile or Email already used by another" to prevent these data from being repeated in different requests, and the claimants themselves cite these controls as obstacles they have encountered when trying to simulate a possible fraud.

Other controls of CIRBOX may result in the cancellation of the request for the following reasons, recorded in the application: expired ID, ID does not correspond to the request, ID not legible or is not an ID, identification with incorrect data, identification with signature problem, incorrect identification document, identification does not identify the applicant. It has been verified that there are canceled requests.

Regarding the data retention period, the collected privacy policy specifies one week for the digital certificate and one month for the reports. Representatives of the entity have stated that the certificate is issued exclusively for the issuance of the requested reports and the reports are available for download for a period of one month exclusively for the company that requested them.

Secondly, in relation to Article 32 of the GDPR, CIRBOX has declared that its employees do not have access to the reports, only to the status of the requests, and checks carried out in the entity's systems have found no evidence of access to the reports by CIRBOX employees.

There is certification that CIRBOX has implemented and maintains an Information Security Management System for the information systems that support the business processes for managing the issuance of digital certificates, according to ISO/IEC 27001:2013 standard. There is also a Certification Practices Statement from UANATACA, Certification Authority.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
16/17

In conclusion, it has been established that there are no rational indications of the existence of an infringement within the jurisdiction of the Spanish Agency for Data Protection, and therefore, the initiation of a sanctioning procedure is not warranted.

It should be noted that Administrative Sanctioning Law, due to its specificity, applies, with some nuances but without exceptions, the guiding principles of criminal law, making it clear that the principle of presumption of innocence is fully applicable.

In this regard, the Constitutional Court, in Judgment 76/1990, considers that the right to the presumption of innocence entails “that the sanction is based on acts or incriminating evidence of the reproached conduct; that the burden of proof lies with the accuser, without anyone being obliged to prove their own innocence; and that any insufficiency in the results of the evidence presented, freely assessed by the sanctioning body, must result in an acquittal.” This principle is expressly enshrined for sanctioning administrative procedures in Article 53.2.b) of Law 39/2015, of October 1, on Common Administrative Procedure of Public Administrations, which recognizes the interested party's right “To the presumption of non-existence of administrative liability until proven otherwise.”

In summary, the application of the principle of presumption of innocence prevents the imputation of an administrative infringement when no evidence or indications have been obtained that derive from the existence of an infringement.

In this case, from the actions taken and the documentation in the procedure, there is no inference of an infringing act by CIRBOX within the jurisdiction of the Spanish Agency for Data Protection, therefore the complaint should be archived.

III

Conclusion

Therefore, based on the information provided in the previous paragraphs, no evidence has been found that substantiates the existence of an infringement within the jurisdiction of the Spanish Agency for Data Protection.

Thus, in accordance with the aforementioned, by the Director of the Spanish Agency for Data Protection,

FIRST: PROCEED TO ARCHIVE the present actions.

SECOND: NOTIFY this resolution to CIRBOX TECNOLOGÍA Y SEGURIDAD, S.L. and to the complainant.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure as provided by art. 114.1.c) of Law 39/2015, of October 1, on Common Administrative Procedure of Public Administrations, and in accordance with the provisions of arts. 112 and 123 of the aforementioned Law 39/2015, of October 1, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es